SAMPLE · FICTIONAL DOMAIN, REAL REPORT STRUCTURE

What one credit delivers

Every finding below comes from a check the scanner really performs. The domain and the evidence are invented. Your report is a PDF in English with this structure, downloadable from the dashboard; the full PDF also contains the methodology and an evidence appendix.

---

1 · Document control

Target	`shop.example.com`	**Assessment type**	External · unauthenticated · read-only
Ownership	Verified via TXT _netsekurity	**Completed**	2026-09-01 09:14 UTC
Prepared by	Netsekurity.com Security Agent	**Classification**	Confidential: owner and operators only

2 · Findings summary

1 High | 2 Medium | 2 Low | 4 Info

Overall posture: needs attention. One file exposure can leak credentials today; the remaining items are hardening.

3 · Risk register

#	Finding	Severity
F-01	Environment file exposed at /.env CVSS 7.5 · CWE-538 · OWASP A05 · A02	High
F-02	Missing security headers (4 of 6) CVSS 5.3 · CWE-1021 · OWASP A05	Medium
F-03	Open redirect via ?next= CVSS 5.4 · CWE-601 · OWASP A01	Medium
F-04	Server version disclosed (nginx/1.18.0) CVSS 3.7 · CWE-200 · OWASP A05	Low
F-05	TLS certificate expires in 41 days CVSS 3.7 · CWE-295 · OWASP A02	Low
I-01…04	DNS resolution · 7 subdomains · WAF detected · robots.txt disallow entries	Info

4 · Findings and analysis

F-01 · Environment file exposed at /.env

High · CVSS 7.5

What we saw: The path /.env returned HTTP 200 with a 1.2 KB body. Files with this name normally hold database passwords, API keys and signing secrets. We did not keep the contents.

Evidence: `GET /.env -> 200 1247`

Impact: Anyone can read your production secrets.

Fix: Block the file at the web server (nginx: `location ~ /\.env { deny all; }`), move it outside the web root, then rotate every secret it contains: assume it has already been read.

F-02 · Missing security headers

Medium · CVSS 5.3

What we saw: The response lacks strict-transport-security, content-security-policy, referrer-policy and permissions-policy. x-frame-options and x-content-type-options are present.

Evidence: `missing=strict-transport-security, content-security-policy, referrer-policy, permissions-policy`

Fix: Add the four headers at the proxy or framework. Start HSTS at max-age=300, raise it to a year once nothing breaks. A CSP of `default-src 'self'` plus your CDN hosts is a safe first version.

F-03 · Open redirect via ?next=

Medium · CVSS 5.4

What we saw: Requesting /?next=https://evil.example answered with a 302 to that external address.

Evidence: `GET /?next=https://evil.example -> 302 https://evil.example`

Impact: Phishing links can carry your real domain and still land on an attacker's page.

Fix: Only accept a relative path that starts with a single /, or check the target against an allowlist of your own hosts.

F-04, F-05 and the four informational items

F-04 · Server version disclosed. `server: nginx/1.18.0` tells an attacker exactly which CVEs to try. Set `server_tokens off;`.

F-05 · Certificate expires in 41 days. Issuer Let's Encrypt, 3 SAN entries. Confirm auto-renewal is running; an expired certificate takes the site offline.

I-01 · DNS. Apex resolves to 203.0.113.10. **I-02 · Subdomains.** 7 hosts found via certificate transparency, including staging.shop.example.com: check it is meant to be public. **I-03 · WAF.** Cloudflare fingerprint present. **I-04 · robots.txt.** Disallows /admin/, which confirms the path exists.

5 · Remediation plan (30 / 60 / 90)

TODAY

Block /.env. Rotate every secret in it.

THIS MONTH

Fix the redirect. Add HSTS, CSP, Referrer-Policy and Permissions-Policy.

NEXT QUARTER

Hide the server version. Decide whether staging. should be public. Re-scan (1 credit) to confirm.

6 · What this report does not cover

Nothing behind a login, no authorisation (IDOR) or business-logic testing, and no injection payloads (SQLi, XSS, LFI). Those need the whitebox tier. A finding that does not appear means “not scanned for”, not “verified safe”. The full list is on the **product scope** page.